

ISO 27001 Comprehensive Information Security Policy

Version 1.0 | Classification: Internal | Owner: CISO | Review cycle: Annual

This policy establishes the organization's Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022. It applies to all personnel, systems, and processes that create, store, transmit, or process organizational information assets. All employees, contractors, and third-party service providers operating within the scope of this policy are required to comply with its requirements.

1. Context of the Organization

1.1 Understanding the Organization and Its Context

The organization shall determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended outcomes of its information security management system (ISMS). The organization identifies, analyses, and regularly reviews these external and internal issues through environmental scanning, stakeholder consultation, and strategic planning processes to ensure the ISMS remains aligned with organizational objectives.

1.2 Needs and Expectations of Interested Parties

The organization shall determine: a) interested parties that are relevant to the information security management system; b) the relevant requirements of these interested parties; and c) which of these requirements will be addressed through the information security management system.

Interested parties include customers, regulators, employees, suppliers, and shareholders. Their requirements are documented, reviewed periodically, and incorporated into the ISMS planning process.

1.3 Determining the Scope of the ISMS

The organization shall determine the boundaries and applicability of the information security management system to establish its scope. When determining this scope, the organization considers: a) the external and internal issues referred to in 4.1; b) the requirements referred to in 4.2; and c) interfaces and dependencies between activities performed by the organization, and those that are performed by other organizations. The scope shall be available as documented information and is published on the organization's intranet and shared with all relevant parties.

2. Information Security Management System

2.1 Establishing and Maintaining the ISMS

The organization shall establish, implement, maintain and continually improve an information security management system, including the processes needed and their interactions, in accordance with the requirements of ISO/IEC 27001:2022. The ISMS covers all organizational assets, processes, personnel, and technology components that handle or process information classified as sensitive, confidential, or critical.

The ISMS is subject to annual review and updated whenever significant changes occur in the organization's context, risk landscape, or regulatory environment. Ownership of the ISMS is assigned to the Chief Information Security Officer (CISO), who is accountable for its effectiveness, adequacy, and continual improvement.

3. Leadership and Commitment

3.1 Leadership Commitment to the ISMS

Top management shall demonstrate leadership and commitment with respect to the information security management system by: a) ensuring the information security policy and the information security objectives are established and are compatible with the strategic direction of the organization; b) ensuring the integration of the information security management system requirements into the organization's processes; c) ensuring that the resources needed for the information security management system are available; d) communicating the importance of effective information security management and of conforming to the information security management system requirements; e) ensuring that the information security management system achieves its intended outcomes; f) directing and supporting persons to contribute to the effectiveness of the information security management system; g) promoting continual improvement; and h) supporting other relevant management roles to demonstrate their leadership as it applies to their areas of responsibility.

3.2 Information Security Policy

Top management shall establish an information security policy that: a) is appropriate to the purpose of the organization; b) includes information security objectives or provides the framework for setting information security objectives; c) includes a commitment to satisfy applicable requirements related to information security; d) includes a commitment to continual improvement of the information security management system. The information security policy shall: e) be available as documented information; f) be communicated within the organization; and g) be available to interested parties, as appropriate.

3.3 Organizational Roles, Responsibilities and Authorities

Top management shall ensure that the responsibilities and authorities for roles relevant to information security are assigned and communicated within the organization. Top management shall assign the responsibility and authority for: a) ensuring that the information security management system conforms to the requirements of this document; and b) reporting on the performance of the information security management system to top management.

Roles include the CISO, Information Security Manager, System Owners, Data Custodians, and all employees who handle organizational information assets.

4. Planning

4.1 Actions to Address Risks and Opportunities

When planning for the information security management system, the organization shall consider the issues referred to in 4.1 and the requirements referred to in 4.2 and determine the risks and opportunities that need to be addressed to: a) ensure the information security management system can achieve its intended outcomes; b) prevent, or reduce, undesired effects; and c) achieve continual improvement. The organization shall plan: d) actions to address these risks and opportunities; and e) how to: 1) integrate and implement the actions into its information security management system processes; and 2) evaluate the effectiveness of these actions.

4.2 Information Security Risk Assessment

The organization shall define and apply an information security risk assessment process that: a) establishes and maintains information security risk criteria that include: 1) the risk acceptance criteria; and 2) criteria for performing information security risk assessments; b) ensures that repeated information security risk assessments produce consistent, valid and comparable results; c) identifies the information security risks: 1) apply the information security risk assessment process to identify risks associated with the loss of

confidentiality, integrity and availability for information within the scope of the information security management system; and 2) identify the risk owners; d) analyses the information security risks: 1) assess the potential consequences that would result if the risks were to materialize; 2) assess the realistic likelihood of the occurrence of the risks; and 3) determine the levels of risk; e) evaluates the information security risks: 1) compare the results of risk analysis with the risk criteria established; and 2) prioritize the analysed risks for risk treatment. The organization shall retain documented information about the information security risk assessment process.

4.3 Information Security Risk Treatment

The organization shall define and apply an information security risk treatment process to: a) select appropriate information security risk treatment options, taking account of the risk assessment results; b) determine all controls that are necessary to implement the information security risk treatment options chosen; c) compare the controls determined above with those in Annex A and verify that no necessary controls have been omitted; d) produce a Statement of Applicability that contains: 1) the necessary controls; 2) justification for their inclusion; 3) whether the necessary controls are implemented or not; and 4) the justification for excluding any of the Annex A controls. e) formulate an information security risk treatment plan; and f) obtain risk owners' approval of the information security risk treatment plan and acceptance of the residual information security risks. The organization shall retain documented information about the information security risk treatment process.

4.4 Information Security Objectives and Planning to Achieve Them

The organization shall establish information security objectives at relevant functions and levels. The information security objectives shall: a) be consistent with the information security policy; b) be measurable (if practicable); c) take into account applicable information security requirements, and results from risk assessment and risk treatment; d) be monitored; e) be communicated; f) be updated as appropriate; and g) be available as documented information. The organization shall retain documented information on the information security objectives. When planning how to achieve its information security objectives, the organization shall determine: h) what will be done; i) what resources will be required; j) who will be responsible; k) when it will be completed; and l) how the results will be evaluated.

4.5 Planning of Changes

When the organization determines the need for changes to the information security management system, the changes shall be carried out in a planned manner, ensuring the continuing integrity and effectiveness of the ISMS throughout any transition.

5. Support

5.1 Resources

The organization shall determine and provide the resources needed for the establishment, implementation, maintenance and continual improvement of the information security management system. Resources include qualified personnel, technology infrastructure, financial budgets, and management time sufficient to support all ISMS activities.

5.2 Competence

The organization shall: a) determine the necessary competence of persons doing work under its control that affects its information security performance; b) ensure that these persons are competent on the basis of appropriate education, training, or experience; c) where applicable, take actions to acquire the necessary competence, and evaluate the effectiveness of the actions taken; and d) retain appropriate documented information as evidence of competence.

All staff with information security responsibilities shall complete mandatory training aligned with their role. Training records are maintained and reviewed annually.

5.3 Awareness

Persons doing work under the organization's control shall be aware of: a) the information security policy; b) their contribution to the effectiveness of the information security management system, including the benefits of improved information security performance; and c) the implications of not conforming with the information security management system requirements.

The organization runs an annual security awareness programme covering phishing, data handling, physical security, and incident reporting obligations.

5.4 Communication

The organization shall determine the need for internal and external communications relevant to the information security management system including: a) on what to communicate; b) when to communicate; c) with whom to communicate; and d) how to communicate.

Internal communications are delivered through the intranet, email bulletins, and team meetings. External communications follow the organization's external communications policy and are approved by the CISO or designated spokesperson.

5.5 Documented Information – General

The organization's information security management system shall include: a) documented information required by this document; and b) documented information determined by the organization as being necessary for the effectiveness of the information security management system.

The extent of documented information can differ from one organization to another due to the size of the organization and its type of activities, processes, products and services, the complexity of processes and their interactions, and the competence of persons.

5.6 Creating and Updating Documented Information

When creating and updating documented information the organization shall ensure appropriate: a) identification and description (e.g. a title, date, author, or reference number); b) format (e.g. language, software version, graphics) and media (e.g. paper, electronic); and c) review and approval for suitability and adequacy.

5.7 Control of Documented Information

Documented information required by the information security management system and by this document shall be controlled to ensure: a) it is available and suitable for use, where and when it is needed; and b) it is adequately protected (e.g. from loss of confidentiality, improper use, or loss of integrity). For the control of documented information, the organization shall address the following activities, as applicable: c) distribution, access, retrieval and use; d) storage and preservation, including the preservation of legibility; e) control of changes (e.g. version control); and f) retention and disposition. Documented information of external origin, determined by the organization to be necessary for the planning and operation of the information security management system, shall be identified as appropriate, and controlled.

6. Operation

6.1 Operational Planning and Control

The organization shall plan, implement and control the processes needed to meet requirements, and to implement the actions determined in Clause 6, by: a) establishing criteria for the processes; and b)

implementing control of the processes in accordance with the criteria. Documented information shall be available to the extent necessary to have confidence that the processes have been carried out as planned. The organization shall control planned changes and review the consequences of unintended changes, taking action to mitigate any adverse effects, as necessary. The organization shall ensure that externally provided processes, products or services that are relevant to the information security management system are controlled.

6.2 Information Security Risk Assessment (Operational)

The organization shall perform information security risk assessments at planned intervals or when significant changes are proposed or occur, taking account of the criteria established for risk assessment. Risk assessments are conducted at least annually, or following any significant incident, organisational change, or new system deployment. The organization shall retain documented information of the results of the information security risk assessments.

6.3 Information Security Risk Treatment (Operational)

The organization shall implement the information security risk treatment plan. Risk treatment decisions are reviewed by senior management and the ISMS Steering Committee. Treatment actions are tracked to completion and verified for effectiveness. The organization shall retain documented information of the results of the information security risk treatment.

7. Performance Evaluation

7.1 Monitoring, Measurement, Analysis and Evaluation

The organization shall determine: a) what needs to be monitored and measured, including information security processes and controls; b) the methods for monitoring, measurement, analysis and evaluation, as applicable, to ensure valid results. The methods selected should produce comparable and reproducible results to be considered valid; c) when the monitoring and measuring shall be performed; d) who shall monitor and measure; e) when the results from monitoring and measurement shall be analysed and evaluated; and f) who shall analyse and evaluate these results. Documented information shall be available as evidence of the results. The organization shall evaluate the information security performance and the effectiveness of the information security management system.

Key performance indicators (KPIs) include: percentage of risks with completed treatment, number of open nonconformities, training completion rates, security incident counts, audit finding resolution rates, and mean time to detect and respond to security events.

7.2 Internal Audit

The organization shall conduct internal audits at planned intervals to provide information on whether the information security management system: a) conforms to: 1) the organization's own requirements for its information security management system; and 2) the requirements of this document; and b) is effectively implemented and maintained.

7.3 Internal Audit Programme

The organization shall plan, establish, implement and maintain an audit programme(s), including the frequency, methods, responsibilities, planning requirements and reporting. When establishing the internal audit programme(s), the organization shall consider the importance of the processes concerned and the results of previous audits. The organization shall: a) define the audit criteria and scope for each audit; b) select auditors and conduct audits that ensure objectivity and the impartiality of the audit process; and c) ensure that the results of the audits are reported to relevant management. Documented information shall be available as evidence of the implementation of the audit programme(s) and the audit results.

7.4 Management Review

Top management shall review the organization's information security management system at planned intervals to ensure its continuing suitability, adequacy and effectiveness.

7.5 Management Review Inputs

The management review shall include consideration of: a) the status of actions from previous management reviews; b) changes in external and internal issues that are relevant to the information security management system; c) changes in needs and expectations of interested parties that are relevant to the information security management system; d) feedback on the information security performance, including trends in: 1) nonconformities and corrective actions; 2) monitoring and measurement results; 3) audit results; 4) fulfilment of information security objectives; e) feedback from interested parties; f) results of risk assessment and status of risk treatment plan; and g) opportunities for continual improvement.

7.6 Management Review Results

The results of the management review shall include decisions related to continual improvement opportunities and any needs for changes to the information security management system. Documented information shall be available as evidence of the results of management reviews.

8. Improvement

8.1 Continual Improvement

The organization shall continually improve the suitability, adequacy and effectiveness of the information security management system. Improvement activities are identified from internal audits, management reviews, incident analysis, corrective actions, and lessons-learned exercises. All improvement actions are tracked through the organization's information security register.

8.2 Nonconformity and Corrective Action

When a nonconformity occurs, the organization shall: a) react to the nonconformity, and as applicable: 1) take action to control and correct it; and 2) deal with the consequences; b) evaluate the need for action to eliminate the causes of nonconformity, in order that it does not recur or occur elsewhere, by: 1) reviewing the nonconformity; 2) determining the causes of the nonconformity; and 3) determining if similar nonconformities exist, or could potentially occur; c) implement any action needed; d) review the effectiveness of any corrective action taken; and e) make changes to the information security management system, if necessary. Corrective actions shall be appropriate to the effects of the nonconformities encountered. Documented information shall be available as evidence of: f) the nature of the nonconformities and any subsequent actions taken; and g) the results of any corrective action.

All nonconformities are logged in the Corrective Action Register, assigned an owner, given a target resolution date, and tracked to closure. The CISO reviews open nonconformities monthly and escalates overdue items to senior management.